

UNIT 1: INTRODUCTION

Dhanashree Kulkarni

Index

- Need for reverse engineering and malware analysis
- Various techniques (static, dynamic, behavioral)
- Steps in reverse engineering, creating lab environment for malware analysis.

What is Malware?

- ❑ Malware is a **code** that **performs malicious actions**; it can take the form of an **executable, script, code**, or any other **software**. Attackers use malware to **steal sensitive information, spy** on the **infected system** or **take control of the system**. It typically **gets into your system without your consent** and can be **delivered** via various communication channels such as **email, web, or USB drives**.
- ❑ The following are some of the malicious actions performed by malware:
 - ❑ Disrupting computer operations
 - ❑ Stealing sensitive information, including personal, business, and financial data
 - ❑ Unauthorized access to the victim's system
 - ❑ Spying on the victims
 - ❑ Sending spam emails
 - ❑ Engaging in distributed-denial-of-service attacks (DDOS)
 - ❑ Locking up the files on the computer and holding them for ransom

Incident Response

- Case history
 - ▣ A medical clinic with 10 offices found malware on one of their workstations
 - ▣ Hired a consultant to clean & re-image that machine
- All done—case closed? NOO!!
 - ▣ Re-imaging answers “Is this PC clean?”
 - ▣ It does not answer “What happened, how, and are we safe now?”

What else should be done

- ❑ Incident Scoping & Containment (Ensure infection did **not spread**)
 - ❑ Identify **type of malware** (ransomware, spyware, trojan, RAT)
 - ❑ **Check** (workstations, Servers etc..)
 - ❑ **Disable** Compromised entities
- ❑ Log & Forensic Review (Understand *how* the malware entered)
 - ❑ **Review** (Logs, alerts, emails)
 - ❑ **Identify** (Initial infection vector, Time of compromise, Data exfiltrated?)
- ❑ Environment-Wide Security Hardening (Prevent repeat incidents)
 - ❑ **Fix the root causes** (Patch OS, Browser, Software)
 - ❑ **Enable / upgrade:** (Endpoint protection, logging system)
 - ❑ **Restrict:** (USB usage, access control etc..)
- ❑ **Incident Documentation & Lessons Learned**
- ❑ **User Awareness & Policy Update**

Moral of the story

- ❑ Malware is a **broad term** that refers to **different types of malicious programs such as trojans, viruses, worms, and rootkits.**
- ❑ While performing **malware analysis**, you will often come across **various types of malicious programs**; some of these malicious programs are **categorized based on their functionality and attack vectors**
- ❑ Malware (malicious software) is any program that **works against the interest of the system's user or owner.**
- ❑ Malware is the most common form of a cyberattack because of its **versatility**. It may involve a virus to a devastating ransomware attack.
- ❑ **Question:**
 - ▣ Is a program that spies on the web browsing habits of the employees of a company considered malware?
 - ▣ What if the CEO authorized the installation of the spying program?

Uses of Malware

- Why do people develop and deploy malware?
 - ▣ Financial gain
 - ▣ Psychological urges and childish desires to “beat the system”.
 - ▣ Access private data

Typical Purposes of Malware attacks

- Backdoor access:
 - ▣ Attacker gains unlimited access to the machine.
- Denial-of-service (DoS) attacks:
 - ▣ Infect a huge number of machines to try simultaneously to connect to a target server in hope of overwhelming it and making it crash.
- Vandalism:
 - ▣ E.g., defacing a web site.
- Resource Theft:
 - ▣ E.g., stealing other user's computing and network resources, such as using your neighbors' Wireless Network.
- Information Theft:
 - ▣ E.g., stealing other user's credit card numbers.

Reverse Engineering

- Reverse Engineering (RE) is the process of analyzing a system, program, or product to understand how it works internally, without access to its original design or source code.
- Reverse engineering is performed to:
 - ▣ Understand program logic and behavior
 - ▣ Detect malicious intent (malware analysis)
 - ▣ Identify vulnerabilities
 - ▣ Recover lost documentation or source logic
 - ▣ Analyze proprietary or legacy systems
 - ▣ Verify software compliance or license violations

Malware Analysis

- ❑ Dissecting malware to understand
 - ▣ How it works
 - ▣ How to identify it
 - ▣ How to defeat or eliminate it
- ❑ A critical part of incident response
 - ▣ Identify the source of an attack
 - ▣ Categorize incidents by the level of severity
 - ▣ Improve the efficiency of the incident response process
 - ▣ Evaluate the potential damage from a security threat
 - ▣ Enrich threat hunting processes

Types of Malware

- ❑ Viruses
- ❑ Worms
- ❑ Trojan Horses
- ❑ Backdoors
- ❑ Mobile code
- ❑ Adware
- ❑ Sticky software

Viruses

- ❑ Viruses are self-replicating programs that usually have a malicious intent.
- ❑ Old fashioned type of malware that has become less popular since the widespread use of the Internet.
- ❑ **The unique aspect of computer viruses is their ability to self-replicate.**
- ❑ However, someone (e.g., user) must execute them in order for them to propagate.

Viruses (Cont'd)

- Some viruses are harmful (e.g.,):
 - ▣ delete valuable information from a computer's disk,
 - ▣ freeze the computer.
- Other viruses are harmless (e.g.,):
 - ▣ display annoying messages to attract user attention,
 - ▣ just replicate themselves.

Viruses: Operation

- Viruses typically attach themselves to executable program files
 - e.g., .exe files in MS Windows
- Then the virus slowly duplicates itself into many executable files on the infected system.
- **Viruses require human intervention to replicate.**

Origin of the term Computer Virus

- The term computer *virus* was first used in an **academic** publication by Fred Cohen in his 1984 paper *Experiments with Computer Viruses*.
- However, a mid-1970s science fiction novel by David Gerrold, *When H.A.R.L.I.E. was One*, includes a description of a fictional computer program called VIRUS.
- John Brunner's 1975 novel *The Shockwave Rider* describes programs known as *tapeworms* which spread through a network for deleting data.
- The term computer virus also appears in the comic book *Uncanny X-Men* in 1982.

The first Computer Viruses

- A program called *Elk Cloner* is credited with being the first computer virus to appear "in the wild". Written in 1982 by Rich Skrenta, it attached itself to the Apple DOS 3.3 operating system and spread by floppy disk.
- The first PC virus was a boot sector virus called Brain, created in 1986 by two brothers, Basit and Amjad Farooq Alvi, operating out of Lahore, Pakistan.

Worms

- Worms are malicious programs that use the Internet to spread.
- Similar to a virus, a worm self-replicates.
- **Unlike a virus, a worm does not need human intervention to replicate.**
- Worms have the ability to spread uncontrollably in a very brief period of time.
 - ▣ Almost every computer system in the world is attached to the same network.

Worms: Operation

- A worm may spread because of a software vulnerability exploit:
 - ▣ Takes advantage of the OS or an application program with program vulnerabilities that allow it to hide in a seemingly innocent data packet.
- A worm may also spread via e-mail.
 - ▣ Mass mailing worms scan the user's contact list and mail themselves to every contact on such a list.
 - ▣ In most cases the user must open an attachment to trigger the spreading of the worm (more like a virus).

Virus or Worm: Malware that is capable of copying itself and spreading to other computers. A virus needs user intervention, whereas a worm can spread without user intervention.

Trojan Horses

- A Trojan Horse is a seemingly innocent application that contains malicious code that is hidden somewhere inside it.
- Trojans are often useful programs that have unnoticeable, yet harmful, side effects.

Trojan Horses: Operation (1)

- Embed a malicious element inside an otherwise benign program.
- The victim:
 1. receives the infected program,
 2. launches it,
 3. remains oblivious of the fact that the system has been infected.
- The application continues to operate normally to eliminate any suspicion.

Trojan Horses: Operation (2)

- Fool users into believing that a file containing a malicious program is really an innocent file such as a video clip or an image.
- This is easy to do on MS Windows because file types are determined by their extension as opposed to examining the file headers.
- E.g.,
 - ▣ “A Great Picture.jpg .exe”
 - ▣ The .exe might not be visible in the browser.
 - ▣ The Trojan author can create a picture icon that is the default icon of MS Windows for .jpg files.

Backdoors

- A backdoor is malware that creates a covert (secret) access channel that the attacker can use for:
 - ▣ connecting,
 - ▣ controlling,
 - ▣ spying,
 - ▣ or otherwise interacting with the victim's system.

Backdoors: Operation

- Backdoors can be embedded in actual programs that, when executed, enable the attacker to connect to and to use the system remotely.
- Backdoors may be planted into the source code by rogue software developers before the product is released.
 - ▣ This is more difficult to get away with if the program is open source.

Mobile Code

- Mobile code is a class of benign(kind) programs that are:
 - ▣ meant to be mobile,
 - ▣ meant to be executed on a large number of systems,
 - ▣ not meant to be installed explicitly by end users.
- Most mobile code is designed to create a more active web browsing experience.
 - ▣ E.g., Java applets, ActiveX controls.

Mobile Code: Operation

- Web sites quickly download and launch a program on the end user's system.
- User might see a message that warns about a program that is about to be installed and launched.
 - ▣ Most users click OK to allow the program to run.
 - ▣ They may not consider the possibility that malicious code is about to be downloaded and executed on their system.

Adware

- Adware is a program that forces unsolicited advertising on end users.
- Adware is a new category of malicious programs that has become very popular.
- Adware is usually bundled with free software that is funded by the advertisements displayed by the Adware program.

Adware: Operation (1)

- The program gathers statistics about the end user's browsing and shopping habits.
 - ▣ The data might be transferred to a remote server.
- Then the Adware uses the information to display targeted advertisements to the end user.

Adware: Operation (2)

- Adware can be buggy and can limit the performance of the infected machine.
 - ▣ E.g., MS IE can freeze for a long time because an Adware DLL is poorly implemented and does not use multithreading properly.
- Ironically, buggy Adware defeats the purpose of the Adware itself.

Sticky Software

- Sticky software implements methods that prevent or deter users from uninstalling it manually.
- One simple solution is not to offer an uninstall program.
- Another solution in Windows involves:
 - ▣ installing registry keys that instruct Windows to always launch the malware as soon as the system is booted.
 - ▣ The malware monitors changes to the registry and replace the keys if they are deleted by the user.
 - ▣ The malware uses two mutually monitoring processes to ensure that the user does not terminate the malware before deleting the keys.

Future Malware

- Today's malware is just the tip of the iceberg.
- The next generation of malware may take control of the low levels of the computer system (e.g., BIOS, Firmware).
 - ▣ The antidote software will be in the control of the malware ...
- Also the theft of valuable information can result in holding it for ransom.

Information-stealing Worms

- Present-day malware does not take advantage of cryptography much.
- Asymmetric encryption creates new possibilities for the creation of information-stealing worms.
- A worm encrypts valuable data on the infected system using an asymmetric cipher and hold the data as ransom.
- Asymmetric encryption introduces two keys:
 - ▣ Public key → embedded in the worm
 - ▣ Private key → held only by the attacker
 - ▣ Worm encrypts stolen data using the attacker's public key
 - ▣ Only the attacker can decrypt it

Information-stealing Worms: Operation

- ❑ The Kleptographic worm embeds a public encryption key in its body.
- ❑ It starts encrypting every bit of valuable data on the host using the public key.
- ❑ Decryption of the data is impossible without the private key.
- ❑ Attacker blackmails the victim demanding ransom.
- ❑ Attacker exchanges the private key for the ransom while maintaining anonymity.
- ❑ **crypto-ransom ecosystems:**
 - ❑ **Worm steals documents**
 - ❑ **Encrypts them with attacker's public key**
 - ❑ **Victim must pay to retrieve their own data**

BIOS/Firmware Malware

- ❑ **Antivirus programs assume that there is always some trusted layer of the system. (File system, OS kernel, Firmware / BIOS)**
- ❑ **Naïve antivirus programs scan the hard drive for infected files using the high-level file-system service.** (Uses OS APIs like open(), read())
- ❑ **A clever virus can intercept file system calls and present to the virus with fake versions (original/uninfected) of the files on disk.** (Alters what antivirus sees)
- ❑ **Sophisticated antivirus programs reside at a low enough level (in OS kernel) so that malware cannot distort their view of the system.**
- ❑ **Moral of the story: Firmware malware runs:**
 - ❑ Before the kernel
 - ❑ Before the OS
 - ❑ Outside antivirus visibility

BIOS/Firmware Malware: Operations

- What if the **malware altered an extremely low level layer** of the system?
- Most CPUs/hardware devices run very low-level code that implements each assembly language instruction using low level instructions (micro-ops).
- The micro-ops code that runs inside the processor is called firmware.
- Firmware can be updated using a firmware-updating program.

Reversing Malware

- ❑ Malware is **vulnerable** to reversing.
- ❑ Reverse engineering malware is the **process of analyzing malware to understand its functionality and purpose**.
- ❑ This process can determine **how to remove the malware from a system or create defenses against it**
- ❑ Reverse engineering malware is challenging, as **malware is often designed to be difficult to analyze**.
- ❑ Threat actors may use **obfuscation** techniques, **encryption**, and other tricks to make the programs more **complex**. In addition, malware authors may **change the code frequently** to make it harder to reverse engineer.

Static and Dynamic Analysis

- ❑ Static analysis checks the code **without running the code**. The analysts use disassembling to reverse engineer the malware in static analysis.
 - ❑ Some other techniques used by static analysis involve **virus scanning, fingerprinting, and memory dumping**. Using static analysis may have limitations against unknown malware types.
- ❑ Dynamic malware analysis **checks the file while running**. The malware is **executed inside a controlled environment called a sandbox to prevent spreading it**. Then, the malware can be reverse engineered to understand its behavior and purpose.
 - ❑ Some techniques used in dynamic malware analysis include **API calls, memory writes, and registry changes**. Since it is typically behavior-based, it can help detect the maliciousness of unknown files.

What Are the Steps of Reverse Engineering?

- ❑ **Acquire** a sample of the malware by downloading it from the internet or receiving it from someone else.
- ❑ **Obtain** a **disassembler** (translates machine code (binary) into low-level assembly language) or **decompiler** (translating that assembly (or directly from machine code) into higher-level, more human-readable code). Many different programs can be used for this purpose.
- ❑ **Use** the disassembler or decompiler to analyze the code of the malware. This will help you understand how the malware works and what it does.
- ❑ **Create** a sandbox environment, which is a safe place where you can run the malware to see what it does without risking infecting your computer.
- ❑ **Run** the malware in the sandbox environment and observe its behavior.
- ❑ **Generate** a **report** of your findings. This will help you communicate your results to others who may be interested in reverse engineering the malware.

Reversing Malware (3):Static Analysis of Malware

- **BinText:**

- Extracts strings from executables, revealing registry keys used, and various commands stored in string format.

- **IDA Pro:**

- Disassembler (executable to assembly code).

- **UPX:**

- UPX compression and decompression, the most common executable packer used by virus and malware writers.

- **Proc Dump:**

- Dumps code from memory.

- **OllyDbg:**

- A debugger that enables the user to attach to a process and insert breakpoints.

Reversing Malware (3):Dynamic Analysis of Malware

- **Process Explorer:**
 - ▣ Tells what processes are currently running.
- **FileMon:**
 - ▣ Monitors files for operations.
- **RegMon:**
 - ▣ Monitors registry for operations.
- **RegShot:**
 - ▣ Takes a snapshot of the registry and associated files .
- **TCPView:**
 - ▣ Displays all TCP and UDP open connections and the process that opened and is using the port.
- **TDIMon:**
 - ▣ Logs network connectivity, but does not log packet contents.
- **Ethereal:**
 - ▣ Packet Scanner that captures packets and supports the viewing of contents/payload.

Timeline of famous malware (1998-2000)

- <https://www.techrepublic.com/article/top-15-cyber-crimes/>

Moral Of the Story...

- ❑ Reverse engineering and malware analysis are two essential components of the cybersecurity field. Though both terms are often used interchangeably, they refer to two **different** types of activities.
- ❑ Reverse engineering is the **process of taking something apart to understand how it works**. This can be applied to **hardware, software, or any other type of system**. Often, reverse engineering is used to create a duplicate or compatible version of a product.
- ❑ Malware analysis, on the other hand, is the **process of studying malware to understand its function and purpose**. This information can then be used to develop ways to protect against or remove malware.

Conclusions

- Educating users on how malware works is important, but not enough.
- Software developers must exercise caution to make their programs more secure from vulnerabilities such as buffer overflow attacks.
- You learned about:
 - ▣ the different types of malware
 - ▣ how malware works
 - ▣ how malware hides from antivirus scanners
- Hands on experience on reversing the BeagleJ virus is a good introduction to reversing and understanding malware.